Enterprise Data Protection, Privacy & Third-Party Sharing Policy

Enterprise Compliance Directive • Ref: POL-PRV-002

ORGANIZATIONAL POLICY MANUAL	**Policy Code:** POL-PRV-002
Document: Enterprise Data Protection, Privacy & Third-Party Sharing Policy	**Version:** 4.1 | **Effective:** 2025-02-01
Category: Data Privacy & Protection	**Business Area:** Legal, Information Security & Engineering
Compliance Owner: Data Protection Officer (DPO)	**Classification:** Confidential - Internal Corporate Use

1. Policy Purpose & Executive Scope

Defines binding rules governing personal data processing, lawful basis, third-party vendor transfers, cross-border data transfer mechanisms, data subject rights, and statutory breach notifications.

2. Binding Regulatory Clauses & Compliance Requirements

Section 1.2: Lawful Basis & Explicit Customer Consent [POL-PRV-002-C01]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: GDPR Article 6 & 7; California Consumer Privacy Act (CCPA) § 1798.120

Customer personal data, including contact records, financial data, and behavioral profiles, must only be processed where a documented lawful basis exists under GDPR Art. 6 or CCPA. Where consent serves as the legal basis, consent must be freely given, specific, informed, and unambiguous. Pre-ticked opt-in checkboxes or bundled terms of service are strictly prohibited.

Section 2.1: Third-Party Data Sharing & Data Processing Agreements (DPA) [POL-PRV-002-C02]

Requirement: MANDATORY | Risk Impact: CRITICAL | Regulatory Base: GDPR Article 28; CPRA § 1798.140

Before disclosing, transmitting, or granting API access to customer personal information with any third-party vendor, partner, or cloud service provider, the business unit must execute a legally binding Data Processing Agreement (DPA) containing standard contractual clauses, purpose limitation restrictions, mandatory sub-processor notification, and right-to-audit provisions. Sharing customer data without a counter-signed DPA is a tier-1 compliance breach.

Section 3.2: Cross-Border Data Transfers & Adequacy Safeguards [POL-PRV-002-C03]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: GDPR Chapter V (Articles 44-49); Schrems II Ruling

Transferring personal data originating in the European Economic Area (EEA), United Kingdom, or Switzerland to jurisdictions outside these territories without an official European Commission Adequacy Decision requires the implementation of EU Standard Contractual Clauses (SCCs) and a completed Transfer Impact Assessment (TIA) signed by the Data Protection Officer.

Section 4.1: Cryptographic Protection & In-Transit / At-Rest Encryption [POL-PRV-002-C04]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: GDPR Article 32; PCI-DSS Requirement 3 & 4; NIST SP 800-52

All customer confidential information, personally identifiable information (PII), and authentication credentials must be encrypted in transit using TLS 1.3 (or minimum TLS 1.2 with forward secrecy) and encrypted at rest using AES-256 or equivalent quantum-resistant cipher suites. Unencrypted transmission via plaintext email or HTTP is grounds for immediate credential revocation.

Section 5.3: Data Subject Access Rights & 30-Day Erasure Mandate [POL-PRV-002-C05]

Requirement: MANDATORY | Risk Impact: MEDIUM | Regulatory Base: GDPR Article 17; CCPA § 1798.105

Upon receiving a verified Data Subject Request (DSR) or Right to Be Forgotten request, the Privacy Operations team must delete or pseudonymize all non-mandatory personal data across primary systems and replica databases within 30 calendar days, unless retention is statutorily required under tax, anti-money laundering, or litigation hold rules.

Section 6.1: Statutory 72-Hour Personal Data Breach Notification [POL-PRV-002-C06]

Requirement: MANDATORY | Risk Impact: CRITICAL | Regulatory Base: GDPR Article 33 & 34; CCPA § 1798.82

In the event of a confirmed or suspected security incident resulting in unlawful destruction, loss, alteration, or unauthorized disclosure of personal data, the Incident Response Commander must notify the Data Protection Officer within 4 hours. The DPO must report the breach to the relevant Supervisory Authority within 72 hours of becoming aware of it.